

Informe Técnico Red Team — Ronda 2

Evaluación Adversarial sobre el Modelo Reentrenado

Proyecto	Operación Centinela	De	Equipo Red Team · Ciberseguridad
Cliente	NovaPay (ficticio)	Para	Equipo Data Science · Blue Team
Fecha	27 de mayo de 2026	Clasificación	Confidencial · Uso interno

1. Contexto y alcance

En esta segunda ronda de la Operación Centinela, el Red Team ha ejecutado una auditoría adversarial dirigida contra el endpoint de scoring `/predict/`, que integra la versión reentrenada del clasificador XGBoost desplegada por el Blue Team tras el informe de Ronda 1. El objetivo no era maximizar la evasión, sino **medir el delta respecto a Ronda 1**: caracterizar cómo el reentrenamiento ha modificado la superficie de decisión y verificar si se han cerrado los puntos ciegos estructurales reportados previamente.

El plan comprendió 85 sondas (probes) sobre identificadores del pool, organizadas en tres líneas de trabajo coordinadas —Reconocimiento, Matriz de ablación y Adaptación quirúrgica—, con la misma metodología de Ronda 1: un usuario fresco por petición, cliente Python reproducible (semilla fija, limitación de frecuencia y registro versionado en CSV). Los usuarios empleados no se solapan con los de Ronda 1.

Atrición de la muestra (23 de 85 peticiones · 27%)

23 peticiones fueron rechazadas con HTTP 403 – "Acceso denegado. Este usuario se encuentra bloqueado." antes de llegar al modelo. Conviene precisar la causa: dado que esta ronda usó usuarios frescos (sin solapamiento con Ronda 1) y una sola petición por usuario, el equipo no pudo agotar por sí mismo el límite de intentos. La explicación más plausible es que esos usuarios **llegaron ya en estado bloqueado por consumo previo de su límite de intentos por otros actores que comparten el pool y el endpoint** (otros equipos del reto o pruebas del propio Blue Team). Esto admite dos lecturas: (a) valida positivamente que el filtro de bloqueo actúa *antes* de la inferencia; y (b) indica que la lista de entrada estaba sucia, lo que redujo la muestra adversarial efectiva a 62 transacciones limpias. Se trata, por tanto, de una incidencia de higiene de datos del experimento, no de un hallazgo sobre el modelo.

Nota metodológica: tras la atrición, los tamaños por hipótesis son reducidos (n = 7-15). Las tasas que siguen son indicativas y deben leerse junto al desglose por condición, no como estimaciones puntuales.

2. Resultados por tipología

Desglose sobre la muestra efectiva de 62 transacciones que completaron la inferencia:

Hipótesis	Naturaleza del vector	n (200)	Prob. media	Pred. 0/1	Estado
T1 · ATO Stealth	Suplantación mimética del titular	8	0,31%	8 / 0	EVADIDO
T2 · Card Testing	Microtransacciones declaradas en ráfaga	9	10,26%	9 / 0	EVADIDO

T4 · Geo Kill-Switch	País de pago de alto riesgo + Desktop + online	7	76,13%	1 / 6	BLOQUEADO
T5 · Adaptación quirúrgica	Importe anómalo en canal limpio (ES/Móvil)	12	79,99%	2 / 10	BLOQUEADO
B1 · Ablación 2×2×2	Aislamiento de Desktop × país × online	15	—*	8 / 7	BIMODAL
B2 · Apilamiento	Prepago + envío ≠ facturación	11	81,15%	1 / 10	BLOQUEADO

* La media de B1 (43%) no es interpretable: la distribución es bimodal (ver §3.1). Se reporta desglosada por celda, no agregada.

3. Hallazgos

3.1 La geografía es el discriminante dominante — y el "kill-switch combinatorio" de R1 era un artefacto

La ablación 2×2×2 aísla por primera vez el efecto de cada factor del combo de Ronda 1. El resultado es inequívoco: el país de pago domina; dispositivo y canal online son secundarios.

Desktop	país ≠ ES	online	n	Prob. media
No	No	No	2	0,4%
No	No	Sí	3	9,0%
Sí	No	Sí	1	15,6%
No	Sí	No	3	62,5%
No	Sí	Sí	3	61,8%
Sí	Sí	No	2	64,6%
Sí	Sí	Sí	1	99,8%

Toda celda con país ≠ ES se sitúa entre 62% y 100% (media 66,9%); toda celda con país = ES, entre 0% y 16% (media 7,2%). Existe una separación de ~45 puntos sin solapamiento. **El factor determinante no es la combinación de los tres elementos, sino la geografía por sí sola;** la lectura de Ronda 1 de un "kill-switch combinatorio" era un artefacto de haber co-variado siempre los tres factores juntos. Este hallazgo se triangula con dos fuentes independientes: el análisis de explicabilidad de T3 (penalización SHAP de país RU de +2,99 a +3,11 y CN de +3,20 a +3,30) y el propio T4 de esta ronda, donde RU (98,7%) y CN (99,2%) saturan el score, pero también DE (58%), FR (74%) y GB (69%) lo elevan sustancialmente: la penalización geográfica se ha ampliado a cualquier país no-ES.

Limitación: la matriz quedó incompleta (7 de 8 celdas; la celda Desktop+ES+offline no obtuvo observaciones por la atrición de 403), y dos celdas tienen n=1. El patrón es direccional y consistente, pero conviene cerrarlo con réplicas en un muestreo posterior.

3.2 El fraude mimético (T1) sigue evadiendo al 100%

T1 mantiene evasión total con probabilidad media de 0,31% (frente a 0,91% en Ronda 1). El modelo continúa evaluando cada transacción como un evento aislado, sin contexto histórico del usuario. Un

atacante con credenciales válidas que replique el comportamiento del titular —importes moderados, comercio y país habituales— goza de impunidad. La recomendación crítica de Ronda 1 (features de comportamiento histórico) no se ha implementado.

3.3 El card testing (T2) sigue evadiendo al 100%

T2 mantiene evasión total. La causa es la misma que en Ronda 1: el campo `minutos_desde_ultima_tx` lo declara el cliente en el cuerpo de la petición y el modelo lo acepta de forma pasiva. El backend no contrasta el tiempo real entre llamadas contra una caché de servidor. Conviene precisar que el intervalo físico real entre nuestras peticiones fue de ~1 s (por la limitación del propio cliente): el modelo nunca observa la velocidad real, solo el valor declarado en el JSON. La recomendación de velocity server-side de Ronda 1 no se ha implementado.

3.4 El sesgo por importe se ha endurecido, pero sobrevive modulado por categoría (T5)

T5 era una adaptación quirúrgica: romper un único elemento del kill-switch (operar desde canal limpio: España, Móvil, sin VPN) manteniendo importes elevados. El resultado debe leerse con honestidad: la adaptación **evadió la geografía pero reintrodujo importe anómalo** (€954–€4.630), que el modelo reentrenado ahora sí penaliza. Es decir, nuestra adaptación fue incompleta. Ahora bien, esa penalización **no es uniforme: está condicionada por la categoría**, y ahí queda una costura explotable:

Importe	Categoría	Prob.	Resultado
4.374 €	Salud	41,0%	EVADE
954 €	Restaurante	28,1%	EVADE
1.936 €	Viajes	98,1%	BLOQUEA

Un importe de €4.374 en Salud evade, mientras €1.936 en Viajes se bloquea. La fuga categórica detectada en Ronda 1 (categorías de baja sospecha que absorben importes anómalos) **sobrevive al reentrenamiento** en Salud y Restaurante. La mejora defensiva es real pero parcial.

3.5 B2: apilamiento de dos señales blandas, no "interferencia destructiva"

La combinación de `tipo_tarjeta = Prepago` y `mismo_envio_facturacion = 0` produce bloqueos fuertes (media 81%). Es importante corregir la interpretación: las dos señales **se suman (efecto constructivo); no se cancelan**, por lo que la hipótesis original de interferencia destructiva no se sostiene. Además, el diseño no permite aislar la interacción —ambos factores se aplicaron siempre juntos y co-variando con importe y categoría—, de modo que no puede atribuirse el efecto a uno u otro con estos datos. Por último, el promedio oculta una evasión: un importe de €45 en Salud con esta misma combinación obtiene 6,3% y evade. Por debajo de cierto umbral de importe en categorías indulgentes, el apilamiento no basta.

4. Recomendaciones

Ordenadas por impacto esperado sobre la detección. Las dos primeras reiteran recomendaciones críticas de Ronda 1 que el análisis confirma como no implementadas.

4.1 Velocity real en servidor — cierra T2

Calcular en el backend el tiempo real transcurrido entre transacciones del mismo usuario a partir de marcas de tiempo de servidor (un *sorted-set* por usuario en Valkey resuelve la consulta en pocos milisegundos) y sobrescribir el campo declarado antes de invocar al modelo.

Advertencia sobre el parche rápido

Una regla dura basada en el valor *declarado* de `minutos_desde_ultima_tx` (p. ej. "si < 3 s, forzar fraude") es trivialmente evadible: el atacante controla ese campo y basta con declarar un intervalo grande. El control **debe** apoyarse en el tiempo medido en servidor, nunca en el valor del payload. Se desaconseja la regla sobre el campo declarado.

4.2 Features de comportamiento histórico por usuario — cierra T1 y la fuga categórica

Enriquecer la inferencia con agregados por `id_usuario` joinados en el backend (media y desviación de importe por categoría en ventanas de 30/90 días, z-score del importe actual frente al histórico del usuario, novedad de país/dispositivo). El z-score condicional dispararía tanto el ATO mimético como los importes anómalos absorbidos hoy por Salud y Restaurante.

4.3 Importe relativo a la categoría y al usuario — cierra la costura de T5/B2

Sustituir el peso del importe absoluto por desviaciones relativas (`z-score` por usuario y categoría; percentil del importe dentro de la categoría como respaldo para cold-start). Es la vía directa para que Salud o Restaurante dejen de comportarse como zonas seguras ante importes elevados.

4.4 Higiene del pool del experimento — incidencia de los 403

Antes de cada ronda, validar el estado de los usuarios de la lista de asignación del experimento y descartar los que ya estén bloqueados. Es una medida de preparación del experimento (no un control de producción) que evita la atrición observada del 27% y preserva el tamaño muestral.

5. Limitaciones del análisis

- La atrición del 27% por bloqueos redujo los tamaños por hipótesis ($n = 7-15$); la matriz de ablación quedó incompleta (7/8 celdas, dos con $n=1$). Los hallazgos son robustos en dirección, no en precisión puntual.
- Pruebas en modo gray-box; el análisis de velocity se realiza sobre el valor declarado del campo, no sobre tiempo real, por diseño del endpoint.
- El Blue Team no comunicó los cambios concretos del reentrenamiento; la atribución de qué cambió se infiere del comportamiento de salida del modelo, no de su implementación.

Quedamos a disposición del Blue Team para los datos brutos por transacción o una sesión conjunta de revisión.